

Threat Hunting Report

Hunt Title: Linux Defense Evasion & Opaque Root Shell Activity

Date: 2025-12-03

Author: SOC Threat Hunter

1. Executive Summary

This hunt focused on identifying credential dumping and persistence mechanisms on Linux endpoints, specifically looking for attempts to access `/etc/shadow` or dump memory. The trigger was a simulation of insider threat activity involving user privilege escalation.

No confirmed credential dumping payload (e.g., specific Python script execution) was identified in the logs. However, significant defense evasion and visibility gaps were discovered: the target user utilized "opaque" interactive root shells (`sudo /bin/bash`) to bypass command logging, and actively attempted to tamper with logging configurations (`filebeat.yml`). This gap renders standard signature-based detection ineffective for this host.

2. Hunt Hypothesis

If an attacker successfully gained local access and escalated privileges to dump credentials, we expect to observe direct access to `/etc/shadow`, execution of known dumping tools (Mimipenguin, Linikatz), or suspicious behavioral patterns such as stopping logging services or modifying network interfaces to prepare for exfiltration.

3. Threat Background

Threat actors targeting Linux environments frequently utilize "Living off the Land" (LotL) binaries to evade detection. Common techniques map to MITRE ATT&CK T1003.008 (`/etc/shadow`) and T1059.004 (Unix Shell).

Threat actors commonly use:

- **Mimipenguin / Linikatz:** Tools to dump cleartext credentials from memory.
- **Interactive Shells:** Spawning `sudo /bin/bash` or `sudo -i` to hide subsequent commands from `syslog` and `auth.log`.
- **Log Tampering:** Deleting agent configurations to blind the SOC.
- **Python/Perl Scripts:** Custom scripts to read shadow files.

The objective is typically credential harvesting for lateral movement.

4. Data Sources Reviewed

Linux System Logs

- `/var/log/syslog` (via Filebeat)
- `/var/log/auth.log` (via Filebeat)
- **Key Finding:** Logs provided high-level session data but lacked process-level visibility inside root shells.

Network Logs

- Interface configuration changes (`ip addr add`) captured in syslog.

Telemetry Gaps

- **Auditd / Auditbeat:** Not enabled. This was a critical missing data source required to see file access (e.g., `/etc/shadow`) or execution inside the bash session.
- **EDR:** No endpoint detection response agent present on momo-VirtualBox.

5. Tools & Techniques Used

- **Elastic Stack (Kibana):** For log aggregation and timeline analysis.
- **KQL (Kusto Query Language):** To filter for sudo usage and file manipulation.
- **Behavioral Analysis:** Correlating "Session Opened" events with lack of subsequent command logs.
- **Keyword Search:** Scanned for shadow, mimikatz, python, dump.

6. Indicators & Behaviors Searched

Behavioral Patterns

- Users executing sudo followed immediately by a shell binary (`/bin/bash`, `/bin/sh`).
- Modification or deletion of `filebeat.yml` or `syslog.conf`.
- Manual network interface reconfiguration (changing IP addresses).
- Process arguments referencing `/etc/shadow`.

IOCs

- Keywords: mimikatz, dump, base64 strings.
- *Note: No static IOCs were found, forcing a reliance on behavioral anomalies.*

7. Queries Used

Elastic (KQL)

Index: filebeat

1. Suspicious Interactive Root Shells (The "Blind Spot")

Code snippet

event.dataset : "system.auth"

AND message : "sudo"

AND message : ("VbinVbash" OR "VbinVsh" OR "VbinVzsh")

2. Logging Configuration Tampering

Code snippet

event.dataset : "system.auth"

AND message : "filebeat.yml"

AND message : ("rm" OR "nano" OR "vim" OR "mv" OR "cp")

8. Findings

8.1 Confirmed Malicious Activity

- **Defense Evasion (Log Tampering):** Confirmed attempt by user abououf to remove the logging agent configuration.
 - Command: /usr/bin/rm /etc/filebeat/filebeat.yml
 - Time: Nov 17, 18:09:52
- **Defense Evasion (Opaque Shells):** Multiple confirmed instances of the user entering unmonitored root sessions.
 - Command: sudo /bin/bash
 - Times: Nov 16 (16:30, 16:32, 16:44), Nov 17 (16:26).

8.2 Suspicious Activity

- **Network Modification:**
 - Command: /usr/sbin/ip addr add 192.168.1.10/24 dev enp0s3

- Context: User manually assigning a static IP, possibly to bypass network controls or prepare for exfiltration.

8.3 Visibility Gaps Found

- **Auditd Missing:** No kernel-level auditing means commands executed *inside* the sudo /bin/bash session were not logged.
- **Shadow File Monitoring:** No telemetry exists to confirm if /etc/shadow was actually read.

9. Impact Assessment

Because the user successfully entered an opaque root shell, any credential dumping tools executed within that session would remain undetected.

- **Detection Risk:** High. The specific attack payload is invisible.
- **Operational Risk:** The user attempted to disable the logging agent (rm filebeat.yml), which could have blinded the SOC permanently for that host.

10. Recommendations

Immediate

- **Enable Auditd:** Install/Enable auditd or Elastic Auditbeat on momo-VirtualBox to capture process execution regardless of the shell.
- **Protect Log Configs:** Set immutable flags (chattr +i) on /etc/filebeat/filebeat.yml to prevent deletion by root users.
- **Alerting:** Enable the "Detection Opportunities" listed below in the SIEM.

Long-term

- **Restrict Sudo:** Review sudoers file. Prevent users from executing /bin/bash or /bin/su via sudo; restrict them to specific binaries only.
- **File Integrity Monitoring (FIM):** Deploy FIM to alert immediately on changes to /etc/shadow or logging configurations.

11. Response

1. **Containment:** Isolate momo-VirtualBox from the network to prevent potential lateral movement or exfiltration.

2. **Investigation:** Snapshot the VM memory and disk. Perform forensic analysis to recover `bash_history` (if not disabled) to see what was typed inside the opaque sessions.
3. **Remediation:** Re-image the host (since root integrity is compromised).
4. **Hardening:** Redeploy with `auditd` enabled and restricted `sudo` permissions.

12. Detection Opportunities (High Value)

These should be turned into alerts or dashboards:

- **Rule: Linux Interactive Root Shell**
 - Logic: Detect `sudo` command where the argument is `bash`, `sh`, `zsh`, or `su`.
- **Rule: Security Config Tampering**
 - Logic: Detect `rm`, `mv`, or editors targeting `/etc/filebeat/*` or `/etc/rsyslog.conf`.
- **Rule: Shadow File Access (Requires Auditd)**
 - Logic: Detect any non-system process opening `/etc/shadow`.
- **Dashboard: "Sudo Usage vs. Command Visibility"** to highlight users frequently spawning raw shells.